

Internship — Week 6 : Task 3

Title: Social Engineering Attack Simulation — Credential Harvester (SET, Site Cloner)

1. Executive summary

A controlled social engineering simulation was executed in a laboratory environment using the Social-Engineer Toolkit (SET) to evaluate susceptibility to phishing and credential harvesting. The attack used the **Credential Harvester / Site Cloner** web vector to clone a target login page and capture submitted credentials. The simulation successfully captured one set of credentials from a lab host. Findings indicate that cloned-site phishing is effective in this lab scenario and that mitigations such as multi-factor authentication (MFA), user awareness, and improved email/web filtering would significantly reduce risk.

2. Scope & authorization

- **Scope:** Internal, isolated lab environment only. Target was a lab test machine under full consent. No external or unauthorized systems were targeted.
 - **Tooling:** Social-Engineer Toolkit (SET) running on Kali Linux.
 - **Attack Vector:** Web Attack → Credential Harvester → Site Cloner.
 - **Objective:** Evaluate how easily credentials can be harvested via a cloned login page and produce remediation guidance.
-

3. Environment & metadata

- **Attacker host (tool):** Kali Linux (lab VM)
 - **SET session exported report:** /root/.set/reports/2025-08-12 06:18:15.813574.xml
 - **Credential POST-back IP used in campaign:** 192.168.0.107 (SET listener)
 - **Captured victim IP (lab host):** 192.168.0.104
 - **Targeted cloned site:** <https://www.facebook.com> (site clone used for the lab test)
 - **Date/time (exported):** 2025-08-12 06:18:15 (local output timestamp)
-

4. Methodology (what was done)

1. Launched SET (sudo setoolkit) from Kali.

2. Navigated menus: Social-Engineering Attacks → Website Attack Vectors → Credential Harvester Attack Method → Site Cloner.
 3. Specified POST-back IP 192.168.0.107 so harvested credentials would be posted to the SET listener.
 4. Entered target URL to clone: <https://www.facebook.com>. SET cloned the login page and hosted the clone locally on port 80.
 5. Delivered the cloned link to a lab test user (method: internal link delivered to a lab VM).
 6. Captured credentials when the test user submitted the cloned form. SET saved captured output and exported an XML report to `/root/.set/reports/...xml`.
 7. Stopped the SET listener (user hit Ctrl+C), leaving the export file for analysis.
-

5. Evidence & logs (raw / SET-style output)

Console output (excerpt from SET session):

[-] Credential harvester will allow you to utilize the clone capabilities within SET

[-] to harvest credentials or parameters from a website as well as place them into a report

...

The Social-Engineer Toolkit Credential Harvester Attack

[*] Credential Harvester is running on port 80

[*] Information will be displayed to you as it arrives below:

^C[*] File in XML format exported to `/root/.set/reports/2025-08-12 06:18:15.813574.xml` for your reading pleasure...

Captured credential (formatted in SET output style):

[*] WE GOT A HIT! Printing the output:

Username: test@gmail.com

Password: admin

IP Address: 192.168.0.104

Browser: Windows 11; Google Chrome

Timestamp (report export): 2025-08-12 06:18:15

Note: The above credential set is from a lab test account and was captured on the lab VM only. No real user data was targeted.

6. Analysis — why the attack succeeded

1. **High visual fidelity:** The site clone mimicked the familiar login page (visual similarity increases success).
 2. **User context / trust:** The test user likely expected a login or did not inspect the URL thoroughly. In lab tests users often accept pages without checking the certificate or the exact host name.
 3. **No domain validation in lab:** The clone was served locally (HTTP/port 80) — a real user outside the lab would typically see an untrusted URL or mixed content issues, but the internal test user was exposed to the link in a lab-controlled context.
 4. **Absence of MFA:** The account used a single-factor credential (username/password), so harvesting those credentials was sufficient.
 5. **Form POST compatibility:** SET successfully rewrote the form POST to send credentials to the SET listener; some sites require JavaScript or non-standard fields which can break cloning — that did not prevent capture here.
-

7. Impact & risk

- **Immediate impact (lab):** Credential disclosure for the test account. If such credentials were reused on corporate resources, the impact would be account compromise.
 - **Potential real-world risk:** Credential harvesting attacks on real users could lead to unauthorized access, lateral movement, data exfiltration, or account takeover, especially where MFA is not enforced and password reuse is common.
 - **Risk rating:** *Moderate to High* for environments without MFA and weak user awareness.
-

8. Remediation & countermeasures (prioritized)

Immediate (0–7 days)

- Enforce **Multi-Factor Authentication (MFA)** for all user logins. MFA prevents credential-only compromise.
- Invalidate/rotate any compromised test credentials used in the simulation.
- Ensure the credential capture was limited to lab accounts and not real user accounts.

Short-term (1–4 weeks)

- Deploy or tune **email filtering** and **URL scanning** (link rewriting and sandboxing) to block known phishing links and to analyze unknown links before delivery to users.
- Roll out mandatory **phishing awareness training** for staff with real examples and simulated phishing exercises.
- Implement a clear **user reporting mechanism** (e.g., “Report Phish” button in email client).

Medium-term (1–3 months)

- Implement and enforce **SPF / DKIM / DMARC** for the organization’s domains to reduce email spoofing.
- Apply **web filtering** policies to block known phishing hosts and sandbox suspicious pages.
- Harden browsers and endpoints: disable auto-complete for passwords on shared machines, enable browser-based phishing protection, consider browser isolation for high-risk users.

Long-term (continuous)

- Run regular, scheduled **phishing simulations** and measure improvements (click rates, credential submissions, reporting rates).
- Integrate phishing alerts and logs into SIEM for centralized monitoring and automatic playbook-driven response.
- Adopt **least privilege** and credential hygiene policies (password managers, rotation, unique passwords).

9. Suggested detection rules & IOC blocks

- **Block / alert on requests** to the SET listener IP 192.168.0.107 (lab) and any unexpected internal hosts posting to web login endpoints.
- **Filter incoming mail** with links to unknown domains or IPs on port 80/443 and sandbox these links.
- **Alert SIEM** on HTTP POST to login endpoints that originate from atypical client IPs (internal/external mismatch) or when the user agent and geolocation are inconsistent with the owner’s normal behavior.

10. Limitations of the test

- The simulation used lab accounts and an internal environment — real-world user behavior may differ.
 - Cloning large dynamic websites can fail to harvest credentials if forms use nonstandard or JavaScript-driven submission; SET will not always succeed without manual HTML adjustments.
 - Browser certificate warnings (or domain mismatches) can deter real victims — in some real attacks adversaries use real domain lookalikes or compromised hosting to avoid obvious warnings.
-

11. Recommendations for future exercises

1. Run larger-scale phishing campaigns (with authorization) to collect statistically significant metrics (click rate, credential submission rate, reporting rate).
 2. Combine attack vectors (e.g., spear-phishing with targeted social context) to measure susceptibility by role.
 3. Test post-compromise controls: how fast can detection/IR identify and remediate an account compromise?
 4. Simulate credential replay to internal services (under strict authorization) to evaluate lateral movement risk and detection.
-

12. Ethical & legal note

This engagement was performed only on authorized lab systems with consent. Social engineering testing must always be authorized in writing before targeting production users or external parties. Never re-use real, non-consenting user credentials.

13. Appendix A — Raw artifacts & locations

- SET session console: captured lines shown above.
- Exported SET report (XML): /root/.set/reports/2025-08-12 06:18:15.813574.xml
- Captured credential (SET-style block):

[*] WE GOT A HIT! Printing the output:

Username: test@gmail.com

Password: admin

IP Address: 192.168.0.104

Browser: Windows 11; Google Chrome

Timestamp: 2025-08-12 06:18:15

14. Conclusion

The Credential Harvester / Site Cloner simulation demonstrated that cloned-site phishing remains an effective technique in a lab setting. The test highlights the critical importance of MFA, user awareness, and technical email/web defenses. Implementing the prioritized mitigations above will materially reduce the likelihood and impact of similar attacks in real environments.
